# AWS Security & Encryption: SAA-C03 Exam Notes

## 1. AWS Security - Section Introduction

- **Shared Responsibility Model:**
  - **AWS:** Security *of* the Cloud (Physical, Hardware, Hypervisor, Managed Services).
  - **Customer:** Security *in* the Cloud (Data, OS patching, Firewall configuration, IAM, Encryption).
- **Principle of Least Privilege:** Always grant only the permissions required to perform a task.
- **Exam Tip:** If a question asks about "Patching the Guest OS" (EC2) or "Configuring Security Groups," that is ALWAYS the **Customer's** responsibility. If it asks about "Disposing of failed hard drives," that is **AWS's** responsibility.

## 2. Encryption 101

- **Encryption in Flight (TLS/SSL):**
  - Data is encrypted before sending and decrypted after receiving.
  - Protects against Man-in-the-Middle (MITM) attacks.
  - Handled by HTTPS endpoints.
- **Encryption at Rest:**
  - Data is encrypted while stored (disk, database, S3).
  - Implemented via keys (KMS) or client-side encryption.
- **Exam Tip:** Any scenario mentioning "compliance requirements to encrypt data traversing the network" refers to **Encryption in Flight** (HTTPS/TLS).

## 3. KMS (Key Management Service) Overview

- **Function:** Managed service to create and control encryption keys.
- **Scope:** Regional service.
- **Exam Concept - Envelope Encryption:**
  - KMS `Encrypt` API has a limit (4KB).
  - For large data (files), use **Envelope Encryption**:
    1. KMS generates a Data Key ( `GenerateDataKey` API).
    2. You use the Data Key to encrypt the file locally.
    3. The encrypted Data Key is stored with the file.
- **Exam Tip:** If you need to encrypt a file **larger than 4KB**, you cannot use the `Encrypt` API directly. You MUST use **Envelope Encryption** (GenerateDataKey).

## 4. Types of KMS Keys (Critical for Exam)

The exam tests your ability to distinguish keys based on **Management** (Cost/Control) and **Key Material Origin**.

## A. By Management (Who manages it?)

| Feature | AWS Owned Keys | AWS Managed Keys | Customer Managed Keys (CMK) |
|---|---|---|---|
| **Example** | S3 default encryption (SSE-S3) | `aws/s3`, `aws/ebs` | Keys you create (`my-app-key`) |
| **Visibility** | **Invisible** (Not in KMS console) | **Visible** | **Visible** |
| **Rotation** | Managed by AWS | Automatic every **1 year** (Mandatory) | Automatic every **1 year** (Optional - must enable) |
| **Permissions** | No control | No control (Policy is Read-Only) | **Full Control** (Key Policy) |
| **Cost** | Free | Free | Paid (~$1/mo + API calls) |
| **Use Case** | Basic compliance | Low overhead, audit needed | **Sharing AMIs**, Cross-account access, specific rotation needs |

## B. By Cryptography

- **Symmetric (AES-256):** Single key for encrypt/decrypt. Used by AWS services (S3, EBS). Key never leaves KMS unencrypted.
- **Asymmetric (RSA/ECC):** Public/Private pair. Used for **Signing** operations or encryption outside of AWS by users without AWS credentials.

## C. By Key Material Origin

- **AWS Generated (Default):** AWS creates the randomness.
- **Imported (BYOK - Bring Your Own Key):**
  - You generate material on-premise and upload it.
  - **Constraint: No Automatic Rotation**. You must manually re-import to rotate.
  - **Risk:** You are responsible for durability; if you lose the source key, data is lost.
- **Custom Key Store:** Keys generated in **CloudHSM** (Single-tenant hardware) but managed via KMS.

# 5. KMS - Multi-Region Keys

- **Standard KMS Keys:** Are strictly regional. You cannot use a key from `us-east-1` to decrypt data in `eu-west-1`.
- **Multi-Region Keys:**

    - Allow you to replicate a Primary Key into other regions as Replica Keys.
    - **Key ID:** The Key ID remains the **same** across regions.
    - **Use Case:** Disaster Recovery (DR) or Global Tables (DynamoDB) where you need to decrypt data instantly in a failover region without re-encrypting.
- **Exam Tip:** If a scenario involves "Global Tables" or "Disaster Recovery" where re-encrypting data in the new region is "too time-consuming," the answer is **Multi-Region Keys**.

## 6. S3 Replication with Encryption

- **Scenario:** Replicating objects from Source Bucket (Region A) to Destination Bucket (Region B).
- **Unencrypted objects:** Replicate automatically (if enabled).
- **Encrypted objects (SSE-KMS):**
    - By default, these are **NOT** replicated. You must specifically enable it in the replication config.
    - **Permissions needed:**
        1. IAM Role for replication must have `kms:Decrypt` permission for the Source Key.
        2. IAM Role must have `kms:Encrypt` permission for the Destination Key.
    - **Throttling:** If KMS limits are hit during replication, you may receive a `ServiceUnavailable` error (Request KMS quota increase).
- **Exam Tip:** If S3 Replication is failing for **only** encrypted objects, verify the **IAM Role permissions** regarding the KMS keys in *both* regions.

## 7. Encrypted AMI Sharing Process

- **Rule:** You **cannot** directly share an AMI encrypted with the default AWS Managed Key.
- **Rule:** You **cannot** share an AMI directly if it is encrypted with a custom key belonging to the *sharer* (the recipient can't access that key).
- **The Workflow:**
    1. Create an AMI from the EC2 instance.
    2. **Copy** the AMI (Image) to the same or new region.
    3. During the Copy process, check "Re-encrypt" and select a **Customer Managed Key (CMK)** that you control.
    4. Add the Target Account ID to the CMK's **Key Policy**.
    5. Share the AMI with the Target Account.
    6. (Optional but recommended) Target Account copies the shared AMI and re-encrypts it with *their own* key to become independent.
- **Exam Tip:** You can never share an AMI encrypted with the "Default" AWS key. You MUST copy it and re-encrypt it with a **CMK** (Customer Managed Key) first.

## 8. SSM Parameter Store Overview

- **Service:** AWS Systems Manager (SSM).
- **Purpose:** Secure, hierarchical storage for configuration data management and secrets management.
- **Types:** String, StringList, SecureString (uses KMS).
- **Tiers:**
  - **Standard:** Free, 10,000 parameter limit, 4KB max size.
  - **Advanced:** Paid, 100,000+ parameters, 8KB max size, supports Policies (expiration).
- **Hierarchy:** `/prod/db/password` or `/dev/app/url`. (Allows path-based IAM permissions).
- **Exam Tip:** If the question asks for "storage of configuration strings" or "secrets" **without** mentioning automatic rotation, choose **SSM Parameter Store** (it's cheaper/free).

## 9. AWS Secrets Manager - Overview

- **Purpose:** Newer service specifically for secrets (passwords, API keys).
- **Key Differentiator vs. SSM Parameter Store:**
  - **Automatic Rotation:** Secrets Manager can automatically rotate credentials for RDS, Redshift, and DocumentDB using Lambda functions.
  - **Cross-Account Access:** Easier to share secrets across accounts.
- **Cost:** More expensive than SSM Parameter Store.
- **Exam Tip:** The keyword is **"Automatic Rotation"**. If the scenario requires rotating DB passwords automatically every X days, the answer is **Secrets Manager**.

## 10. AWS Certificate Manager (ACM)

- **Purpose:** Provision, manage, and deploy SSL/TLS Certificates.
- **Integrations:** Load Balancers (ALB/NLB), CloudFront, API Gateway.
- **Public Certificates:** Free, auto-renewing (if DNS is validated via CNAME).
- **Private Certificates:** Paid (via private CA).
- **Limitations:**
  - You **cannot** export public ACM certificates (private keys) to use on EC2 instances directly. You must put the EC2 behind a Load Balancer or CloudFront to use the ACM cert.
- **Exam Tip:** If you have a legacy application on EC2 that needs a certificate installed *directly* on the OS (not on a Load Balancer), you **cannot** use ACM public certs. You must buy a cert externally and import it, or use ACM Private CA.

## 11. AWS CloudHSM (Hardware Security Module) - Overview

- **Definition:** A dedicated physical hardware security module in the AWS cloud.

- **Key Characteristic:** Single-tenant (Dedicated) hardware.
- **Access Control:** You have full control over the hardware and user accounts. AWS has **zero access** (even they cannot recover lost keys).
- **Compliance: FIPS 140-2 Level 3** (Higher security standard than KMS).
- **Supported Interfaces:** Standard industry protocols:
  - **PKCS#11**
  - **JCE** (Java Cryptography Extension)
  - **Microsoft CNG** (Cryptography Next Generation)
- **Use Cases:**
  - Strict regulatory compliance requiring dedicated hardware.
  - SSL Offloading for Web Servers (e.g., Nginx/Apache) to dedicated hardware.
  - Oracle TDE (Transparent Data Encryption) with master keys in HSM.

## 12. AWS CloudHSM vs. AWS KMS (Comparison)

- **AWS KMS:** Multi-tenant managed service. AWS manages the hardware root of trust.
- **AWS CloudHSM:** Single-tenant dedicated hardware. You manage the hardware.

| Feature | AWS KMS | AWS CloudHSM |
|---|---|---|
| **Tenancy** | **Multi-tenant** (Shared Hardware) | **Single-tenant** (Dedicated Hardware) |
| **Key Recovery** | AWS ensures durability. | **Lost forever** if you lose credentials. |
| **Compliance** | FIPS 140-2 Level 2 (Standard). | **FIPS 140-2 Level 3** (High Security). |
| **Protocols** | AWS API / CLI / SDK Only. | PKCS#11, JCE, Microsoft CNG. |
| **Management** | AWS manages administration. | YOU manage administration. |

- **Exam Tip:** Look for keywords: "Single-tenant," "Dedicated Hardware," "FIPS 140-2 Level 3," or "PKCS#11." These **always** point to **CloudHSM**.

## 13. Web Application Firewall (WAF)

- **Layer:** Layer 7 (Application Layer).
- **Protects Against:** Common web exploits (SQL Injection, Cross-Site Scripting (XSS), Bad bots).
- **Deployable On:**
  - Application Load Balancer (ALB).
  - API Gateway.
  - CloudFront.
  - AppSync.
- **Components:** Web ACLs (Access Control Lists) -> Rules (IP Sets, Geo-Match, String Match).

- **Exam Tip:** If you need to block an attack containing **SQL Injection** or block traffic from a **specific country**, use **WAF**.

## 14. AWS Shield - DDoS Protection

- **Shield Standard:**
  - Free, enabled by default for all customers.
  - Protects against Layer 3 (Network) & Layer 4 (Transport) attacks (SYN Floods, UDP Floods).
- **Shield Advanced:**
  - Paid (approx $3,000/month).
  - Protects against sophisticated Layer 3, 4, and 7 attacks.
  - **Benefits:**
    - 24/7 access to DDoS Response Team (DRT).
    - **Cost Protection:** Reimburses bill spikes caused by DDoS (e.g., scaling up due to attack traffic).
    - Includes WAF for free.
- **Exam Tip:** If a company is worried about **"cost spikes"** due to a DDoS attack scaling up their ASG, the answer is **Shield Advanced** (Cost Protection).

## 15. AWS Firewall Manager

- **Purpose:** Manage security rules across **all** accounts in an AWS Organization from a central location.
- **Prerequisite:** Requires AWS Organizations.
- **What it manages:** WAF rules, AWS Shield Advanced, Security Groups, Network Firewall policies.
- **Use Case:** "Ensure a specific WAF rule is applied to every ALB in the organization."
- **Exam Tip:** If the question asks for "Centralized management of WAF rules across **multiple accounts**," choose **Firewall Manager**.

## 16. DDoS Protection Best Practices (Exam Scenarios)

1. **Reduce Attack Surface:** Use **CloudFront** (caches content at edge) + **WAF** (filters bad requests) + **Shield** (DDoS mitigation).
2. **Scale:** Use **Auto Scaling Groups** to absorb attack traffic.
3. **Hide Origins:** Use Security Groups to ensure ALBs/EC2s only accept traffic from CloudFront IP ranges (Managed Prefix Lists).

- **Exam Tip:** The "Ultimate" DDoS architecture almost always involves **CloudFront** sitting in front of your application (S3 or ALB).

## 17. Amazon GuardDuty

- **Type:** Intelligent Threat Detection.
- **Mechanism:** Uses Machine Learning to analyze logs.
- **Data Sources:**
  1. CloudTrail Management Events.
  2. VPC Flow Logs.
  3. DNS Logs.
  4. EKS Audit Logs / RDS Login events.
- **Example Alerts:** "Instance communicating with known malicious IP," "Cryptocurrency mining detected," "Unusual API calls."
- **Action:** It does *not* block traffic automatically. It sends findings to Security Hub / EventBridge (which can trigger Lambda to remediate).
- **Exam Tip:** GuardDuty detects **"Cryptocurrency Mining"**. Also, remember it only *detects* (using logs); it does not *block* (it's not a firewall).

## 18. Amazon Inspector

- **Type:** Automated Vulnerability Management.
- **Scope:**
  - **EC2 Instances:** Scans for OS vulnerabilities (CVEs) and unintended network exposure. Requires SSM Agent (Systems Manager) for deep scanning.
  - **Container Images (ECR):** Scans images pushed to ECR for vulnerabilities.
  - **Lambda Functions:** Scans code for vulnerabilities.
- **Keyword:** "Assess application for vulnerabilities/exposure," "CVE Check."
- **Exam Tip:** If the question mentions **"Package Vulnerabilities"** or **"Common Vulnerabilities and Exposures (CVE),"** the answer is **Inspector**.

## 19. Amazon Macie

- **Type:** Data Privacy and Security.
- **Target: Amazon S3** only.
- **Mechanism:** Uses ML and pattern matching to discover **Sensitive Data** (PII - Personally Identifiable Information like Credit Cards, SSNs, Passports).
- **Alerts:** Generates alerts in EventBridge when sensitive data is found in unencrypted/public buckets.
- **Exam Tip:** Macie = **PII** (Personally Identifiable Information) in **S3**. It does not work for databases (DynamoDB/RDS), only S3.